# SECURITE DES SYSTEMES

# ET RESEAUX

Services de Securite Avances (UTM & IPS)

Créé par Rachid Bouselama

- Unified Threat Management (UTM)
- Inspection SSL et Filtrage Web
- Prevention d'Intrusion (IPS)

# Table des Matieres

(Clic droit > Mettre a jour le champ pour actualiser les numeros de page)

**Table des Matieres** ..... **2**

**Partie I : Theorie - UTM et Inspection** ..... **3**

1. Le concept UTM (Unified Threat Management) ..... 3
2. Modes d'Inspection : Flow vs Proxy ..... 3
   - 2.1 Inspection Flow-based (Basee sur le flux) ..... 3
   - 2.2 Inspection Proxy-based (Basee sur le proxy) ..... 4
3. Inspection SSL (Le nerf de la guerre) ..... 4
   - 3.1 Certificate Inspection ..... 4
   - 3.2 Deep Inspection (Full SSL) ..... 5

**Partie II : Fiche Labo - Durcissement (Hardening)** ..... **6**

4. Prerequis ..... 6
5. Etape 1 : Web Filtering (Controle des employes) ..... 6
   - 5.1 Creation du Profil Web Filter ..... 6
   - 5.2 Application a la Politique Firewall ..... 7
   - 5.3 Test de validation ..... 8
6. Etape 2 : Antivirus (Protection contre les malwares) ..... **Erreur ! Signet non défini.**
   - 6.1 Configuration de l'Antivirus ..... **Erreur ! Signet non défini.**
   - 6.2 Test avec le fichier EICAR ..... **Erreur ! Signet non défini.**
7. Etape 3 : IPS - Prevention d'Intrusion (Le Grand Final) ..... **Erreur ! Signet non défini.**
   - 7.1 Creation d'une Politique "LAN vers DMZ" ..... **Erreur ! Signet non défini.**
   - 7.2 L'Attaque (Red Team vs Blue Team) ..... **Erreur ! Signet non défini.**
   - 7.3 Verification des logs IPS ..... **Erreur ! Signet non défini.**
8. Livrable ..... **Erreur ! Signet non défini.**

# Partie I : Theorie - UTM et Inspection

Cette partie presente les concepts fondamentaux de la securite reseau moderne, en se concentrant sur les technologies UTM (Unified Threat Management) et les techniques d'inspection du trafic. Ces connaissances sont essentielles pour comprendre comment proteger efficacement un reseau contre les menaces contemporaines.

## 1. Le concept UTM (Unified Threat Management)

Un pare-feu UTM (Unified Threat Management) represente une evolution majeure de la securite reseau. Contrairement aux pare-feu traditionnels qui se contentent de filtrer le trafic par ports et adresses IP, l'UTM integre plusieurs moteurs de securite au sein d'une seule appliance. Cette consolidation offre une protection multicouche tout en simplifiant la gestion.

**Les composants principaux d'un UTM :**

| Composant | Description |
|---|---|
| Antivirus | Analyse les fichiers en transit (HTTP, FTP, SMTP) pour detecter les malwares |
| Web Filtering | Bloque les sites par categorie (Jeu, Adulte, Hacking) via FortiGuard |
| IPS | Analyse les paquets pour trouver des signatures d'attaques connues |
| Application Control | Identifie l'application (YouTube, BitTorrent) meme sur les ports 80/443 |

L'avantage majeur de l'approche UTM reside dans sa capacite a partager des informations entre les differents modules. Par exemple, si l'antivirus detecte un fichier malveillant, cette information peut etre utilisee par le systeme IPS pour bloquer automatiquement la source de l'attaque.

## 2. Modes d'Inspection : Flow vs Proxy

Le choix du mode d'inspection est une decision critique qui impacte directement les performances et l'efficacite de la securite. Ces deux modes representent des philosophies differentes dans l'analyse du trafic reseau.

### 2.1 Inspection Flow-based (Basee sur le flux)

Dans ce mode, le pare-feu analyse les paquets "a la volee" sans les stocker completement en memoire. Chaque paquet est examine individuellement ou en petites sequences, puis transmis immediatement vers sa destination.

> **Avantages :** • Performance elevee avec une latence minimale • Consommation memoire reduite • Mode par defaut des FortiGate modernes

**Limites :**• Moins efficace sur les fichiers complexes (archives ZIP imbriquees) • Impossible de reconstituer completement certains contenus

### 2.2 Inspection Proxy-based (Basee sur le proxy)

Le mode proxy adopte une approche differente : le pare-feu intercepte la communication complete, reconstitue le fichier ou la page entiere en memoire, effectue une analyse approfondie, puis transmet le contenu au client. Le FortiGate agit litteralement comme un intermediaire (proxy) entre le client et le serveur.

**Avantages :**• Precision maximale dans la detection des menaces • Possibilite de reecrire le contenu HTML • Controle granulaire des applications

**Limites :**• Latence accrue due au buffering • Consommation elevee de CPU et memoire • Peut impacter l'experience utilisateur

**Tableau comparatif :**

| Critere | Flow-based | Proxy-based |
|---|---|---|
| Performance | Elevee (faible latence) | Moyenne (latence accrue) |
| Precision | Bonne | Excellente |
| Ressources | Faible (CPU/RAM) | Elevee (CPU/RAM) |
| Fichiers complexes | Limite | Excellent |
| Use case | Trafic standard | Securite maximale |

## 3. Inspection SSL (Le nerf de la guerre)

Aujourd'hui, plus de 90% du trafic web est chiffre via HTTPS. Sans capacite a inspecter ce trafic chiffre, un pare-feu reste aveugle aux menaces qui s'y dissimulent. L'inspection SSL est donc devenue un element critique de toute strategie de securite.

**Deux niveaux d'inspection SSL :**

### 3.1 Certificate Inspection

Cette methode verifie uniquement la validite du certificat SSL/TLS presente par le serveur. Elle s'assure que le certificat n'est pas expire, qu'il est emis par une autorite de confiance, et qu'il correspond au nom de domaine visite. Cette inspection est rapide mais ne permet pas d'analyser le contenu reel de la communication.

### 3.2 Deep Inspection (Full SSL)

La Deep Inspection implemente ce qu'on appelle un "Man-in-the-Middle" legitime. Voici comment cela fonctionne :

1. Le FortiGate intercepte la connexion SSL du client

2. Il etablit une connexion SSL avec le serveur distant

3. Il genere dynamiquement un certificat pour le site visite, signe par sa propre autorite de certification (CA)

4. Le client recoit ce certificat genere

5. Le FortiGate dechiffre le trafic, l'analyse, puis le rechiffre avant de le transmettre

> **Important :**Pour que la Deep Inspection fonctionne correctement, le certificat CA du FortiGate doit etre deploye sur tous les postes clients. Sans cela, les navigateurs afficheront des avertissements de securite pour chaque site visite.

# Partie II : Fiche Labo - Durcissement (Hardening)

Cette partie pratique vous guide dans la configuration des fonctionnalites de securite avancees du FortiGate. Vous allez mettre en place un systeme de defense en profondeur en configurant le filtrage web, l'antivirus et la prevention d'intrusion.

> **Objectif de la seance :**Lors de la Seance 2, vous avez pirate un serveur via une faille Samba. Aujourd'hui, en tant qu'Architecte Securite, vous allez configurer le FortiGate pour detecter et bloquer cette attaque specifique, ainsi que filtrer le contenu web des utilisateurs.

## 4. Prerequis

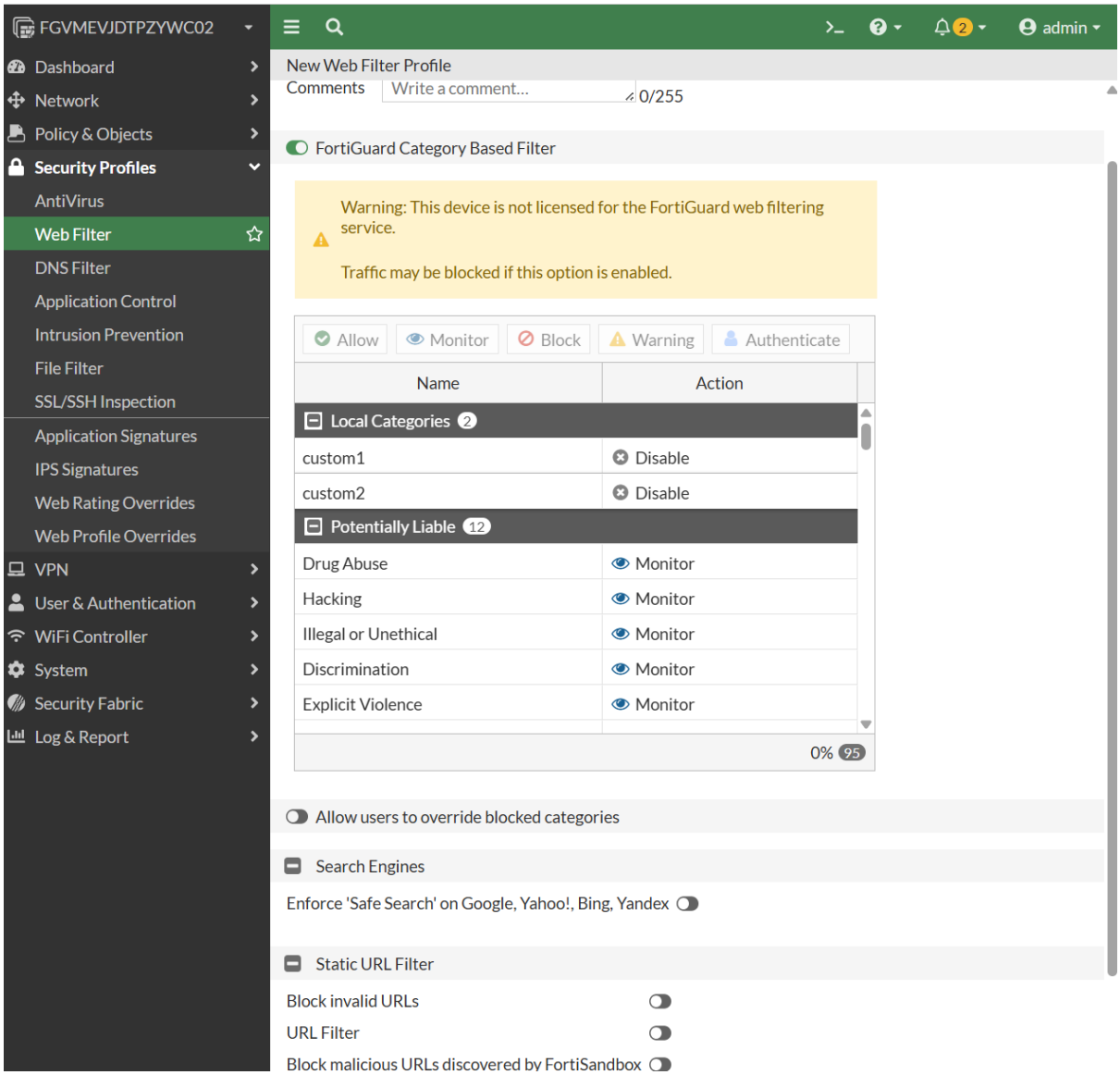
- ☐ Le labo de la Seance 4 doit etre fonctionnel (Ping OK entre Kali et Internet)
- ☐ Acces GUI au FortiGate via le navigateur web
- ☐ Machine Kali Linux operationnelle
- ☐ Serveur Metasploitable accessible en DMZ

## 5. Etape 1 : Web Filtering (Controle des employes)

Nous allons empecher les utilisateurs du LAN (Kali) d'acceder a des sites de piratage et autres contenus inappropries. Cette fonctionnalite est essentielle dans tout environnement professionnel pour garantir la productivite et la securite.

### 5.1 Creation du Profil Web Filter

1. **Acceder au menu :**Security Profiles > Web Filter
2. **Creer un nouveau profil :**Cliquer sur "Create New" et nommer le profil : Block Bad Sites
3. **Activer le filtrage :**Activer "FortiGuard Category Based Filter"
4. **Configurer les categories :**Dans la categorie "Security Risk", bloquer : - Malicious Websites - Spam
5. **Bloquer les jeux et hacking :**Dans "General Interest - Personal", bloquer : - Hacking - Games
6. **Definir l'action :**Action : Block




## 5.2 Application a la Politique Firewall

1 **Acceder aux politiques :**Policy > Firewall Policy

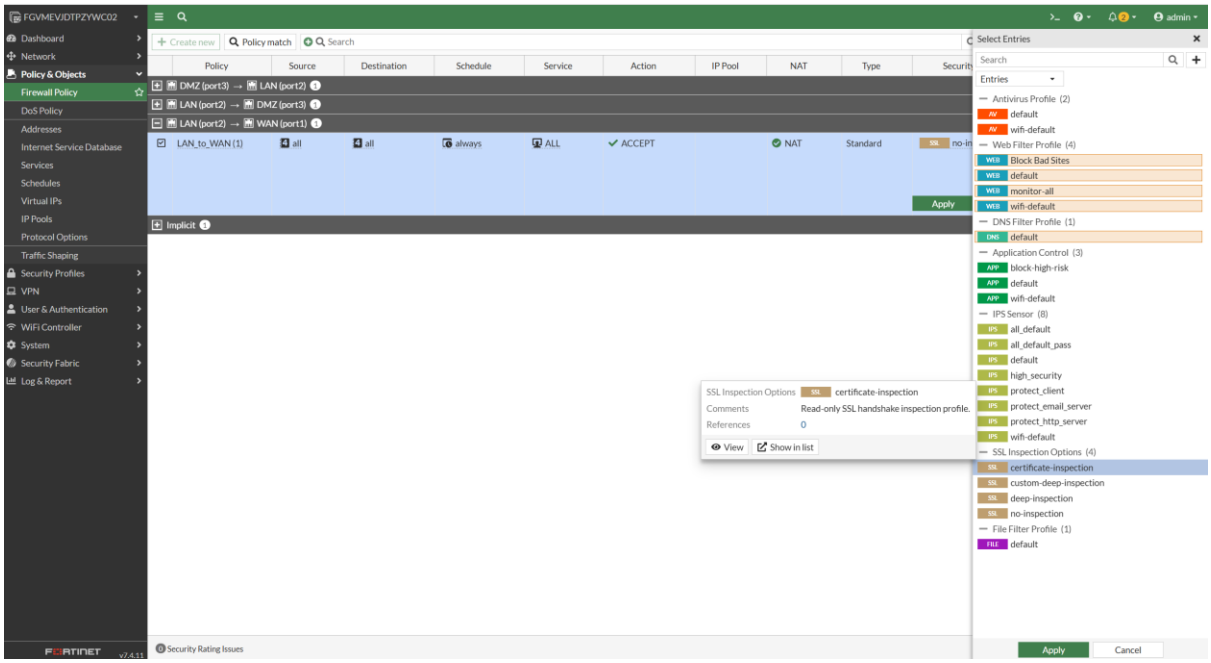
2 **Editer la regle :**Editer la regle "LAN to WAN"

3 **Activer le profil :**Section Security Profiles : Activer Web Filter

4 **Selectionner le profil :**Selectionner "Block Bad Sites"

5 **Configurer SSL Inspection :**Activer SSL Inspection en mode "Certificate-inspection" (suffisant pour le filtrage web simple)

6 **Valider :**Cliquer sur OK pour sauvegarder




## 5.3 Test de validation

Depuis le navigateur de Kali, tentez d'acceder aux sites suivants :

| Site teste | Resultat attendu |
|---|---|
| www.hackthissite.org | Bloque - Page FortiGuard rouge |
| Un site de jeux en ligne | Bloque - Page FortiGuard rouge |
| www.google.com | Autorise - Navigation normale |